# Análisis de Malware

## Definiciones

### Malware

- Es cualquier aplicación diseñada para perjudicar a un usuario, sistema o red.
- Por ejemplo: virus, troyanos, gusanos, rootkits, ransomware, spyware, etc.

### Análisis de malware

- Es la "disciplina" de examinar un programa dañino para comprender su funcionamiento, determinar su impacto, e identificar las vías para detectarlo, neutralizarlo y erradicarlo.

# Objetivo del análisis de malware / Indicadores de compromiso

- Además de entender qué hace un binario, otro objetivo es identificar indicadores de compromiso.
- Los IOCs (Indicators Of Compromise) pueden ser usados para ayudar a detectar malware en otras PC a partir de archivos asociados o comportamiento de red observado.
- Los IOC se utilizan para realizar firmas de antivirus, reglas de IDS y cualquier herramienta que se quiera utilizar para determinar si una PC está infectada.

Existen de dos tipos de IOC:

- Basados en host.
- Basados en red.

## Basados en el equipo host (host-based signatures)

Buscan cambios que pudo haber realizado el malware en el equipo infectado:

- Archivos creados o modificados: PATH, HASH.
- Cambios en la registry.
- Nuevos servicios creados.
- Nuevas tareas programadas.

## De red (network signatures)

Usadas para detectar presencia de código malicioso al monitorear el tráfico de red:

- URLs accedidas: Se está intentando descargar un archivo determinado.
- Direcciones IPs:
  - Se intenta realizar una conexión con un servidor determinado, por ejemplo servidor C2.
  - Se intenta exfiltrar información.

# Técnicas de análisis de malware

## Análisis estático

El primer enfoque para analizar una muestra de malware es mediante un análisis estático; que consiste en examinar el archivo malicioso **sin** ejecutarlo. Se busca conseguir información sobre su funcionalidad analizando su contenido y la estructura del archivo.

A esta de técnica, se la considera segura porque no es necesario ejecutar el código y por ende no representa una amenaza para la máquina donde se lo analiza.

## Análisis estático

La información útil con la que podemos dar en esta etapa:

- Información presente en motores de antivirus existentes.
- Estructura de los archivos:
  - Análisis de las secciones del ejecutable.
  - Librerías y funciones dentro de las mismas importadas.
  - Funciones exportadas.
  - Recursos contenidos.
  - Uso de empaquetador o packers.
  - Strings observados.

# Análisis estático - Herramientas

## Antivirus

Un buen primer paso para realizar este tipo de análisis, es analizar el archivo sospechoso con distintos antivirus. La razón de esto es que alguno de los motores de estos pudo haberlo identificado y nos pueda dar información valiosa sobre la amenaza.

# Antivirus

- Los antivirus se basan principalmente en una base de datos de piezas identificables de código sospechoso (firmas de archivo), así como en el análisis de patrones y comportamiento (heurísticas) para detectar los archivos maliciosos.
- Sin embargo, los antivirus no son infalibles.
- Como los distintos antivirus usan diferentes firmas y heurísticas, es útil verificar el archivo sospechoso utilizando diversos antivirus.

# Estructura de los archivos ejecutables

Los archivos ejecutables, ya sean de Linux o windows, tienen un formato y estructura definida, lo cual puede revelar información importante. Entre los formatos de binarios y librerías más conocidos, podemos mencionar:

- PE (Portable Executable): Formato de archivo para ejecutables (.exe), código objeto y DLLs usado en versiones de 32 y 64 bits del sistema operativo Windows.
- ELF (Executable and Linkable Format): Formato de archivo para ejecutables, código objeto, bibliotecas compartidas, y volcados de núcleo. Usado en Linux, Unix y Mac.

# Estructura de los archivos ejecutables

Los archivos binarios, tanto PE como ELF, están compuestos por una gran colección de headers y secciones.

- Los headers tienen un significado particular y almacenan un valor particular. Por ejemplo: Fecha de creación, última vez modificado, número de secciones, etc.
- Las secciones son colecciones lógicas de código o datos; tienen permisos (lectura, escritura, ejecución) y tienen un nombre.

# Estructura de los archivos ejecutables - Secciones

Por ejemplo en un PE, las secciones más comunes son:

- .text : Contiene el código máquina, las instrucciones del proceso que se van a ejecutar en la CPU.
- .rdata: Contiene datos de solo lectura que son accesibles globalmente por el proceso.
- .data: Contiene constantes las cuales son accesibles desde cualquier parte del programa.

# Estructura de los archivos ejecutables - Secciones

- .idata: A veces presente, almacena información sobre funciones importadas de otras librerías, si no está presente esta información se carga en la sección .rdata.
- .edata: A veces, almacena información de funciones exportadas. Si no está presente esta información se carga en la sección .rdata.
- .rsrc: Almacena distintos tipos de recursos utilizados por el ejecutable.

# Estructura de los archivos ejecutables

Mirando la estructura del binario, podremos conseguir información valiosa como:

- Anomalías en las secciones.
- Información valiosa en la sección de recursos .rsrc.
- Qué librerías externas carga para su funcionamiento.
- Que funciones de librerías son utilizadas.
- Que funciones exporta, al estilo de las DLLs.

Dependiendo de las librerías y funciones que use, nos podemos dar una idea de que hace, o al menos si el binario es malicioso.

# Estructura de los archivos ejecutables

- La sección de recursos puede dar información importante como menús, iconos, o incluso podría alojar un ejecutable por ejemplo.
- Por último, se puede determinar si el binario está empaquetado. El malware frecuentemente está empaquetado u ofuscado para hacerlos más difíciles de detectar o analizar.
- Al ofuscar un programa se intenta ocultar su funcionamiento. Los programas empaquetados son un subconjunto de programas ofuscados en los cuales el programa malicioso es comprimido y no puede ser analizado fácilmente.

## Estructura de los archivos ejecutables

En caso de detectar que el binario está empaquetado, si es posible desempaquetarlo, deberíamos volver a realizar las acciones anteriores:

- Detecciones de motores de antivirus existentes
- Estructura de los archivos:
  - Análisis de las secciones del ejecutable.
  - Librerías y funciones dentro de las mismas importadas.
  - Funciones exportadas.

## Observar Strings en el binario

Adicionalmente, se puede analizar el archivo malicioso buscando strings sospechosos. En los strings se pueden identificar indicadores de compromiso como:

- Direcciones IP.
- URLs.
- Cadenas de caracteres.

## Herramientas para análisis de PE

- Antivirus: https://www.virustotal.com
- Para analizar la estructura de los archivos:
  - Para Windows: CFF Explorer / Pestudio / ResourceHacker / strings

# Análisis dinámico básico

- Cuando ya no podemos extraer más información del archivo, sea porque está fuertemente ofuscado, empaquetado o porque hemos agotado las técnicas de análisis estático disponible, podemos proceder a analizarlo dinámicamente.
- Con análisis dinámico, se hace referencia a monitorear el malware mientras el mismo es ejecutado. El objetivo es comprobar el estado del sistema cuando ya ha terminado la ejecución y detectar las diferencias respecto al estado previo a la ejecución.
- Este tipo de análisis nos permite conocer la funcionalidad real del malware. Por ejemplo, la existencia de un import de una función no quiere decir que efectivamente esa función se vaya a llamar y ejecutar.

## Análisis dinámico básico

- Para realizar este tipo de análisis, como vamos a estar ejecutando programas maliciosos, para evitar que se dañe el equipo y/o se infecten otras máquinas, debemos hacerlo en un ambiente seguro y controlado.
- Es factible utilizar una máquina virtual y tomar las precauciones necesarias a la hora de configurar la red de modo de que el malware no pueda conectarse a otras redes.

# Análisis dinámico básico - Snapshots

Los snapshots nos permiten salvar el estado completo del sistema para poder más tarde volver a ese mismo punto.

Una buena práctica es instalar el SO, todas las herramientas de análisis que vayamos a usar, configurar la red y tomar el snapshot. A partir de allí usaremos ese snapshot como base y cuando terminemos de realizar el análisis de una muestra de malware, podremos volver al estado inicial y limpio, de manera fácil.

# Análisis dinámico básico - Herramientas

## Regshot

Permite comparar snapshots del Registro de windows

- Tomamos un primer snapshot de la registry antes de ejecutar el malware.
- Ejecutamos el malware y esperamos a que termine de hacer cualquier cambio en el sistema.
- Tomamos un segundo snapshot de la registry.
- La herramienta comparará las dos capturas y nos mostrará rápidamente un log con las diferencias.

# Análisis dinámico básico - Herramientas

## Monitorear con Process Monitor

- Process Monitor o procmon es una herramienta de Windows para monitorear actividad en el registro, el sistema de archivos, la red y los procesos.
  - Registro: Podremos ver si el malware se instala a sí mismo en el registro.
  - Sistema de archivos: Podremos ver todos los archivos que el malware crea o los archivos de configuración que usa.
  - Procesos: Podremos ver si el malware inició procesos adicionales.
  - Red: Podremos identificar los puertos donde el malware está escuchando.
  - Procmon tiene la capacidad de capturar toda esa actividad en el periodo de tiempo que le indiquemos. Al utilizar este programa nos damos una idea más certera de que hace el programa que estamos analizando.

# Análisis dinámico básico - Herramientas

## Analizar los procesos con Process Explorer

- Provee información valiosa sobre los procesos que están corriendo actualmente en el sistema y los muestra en una estructura de árbol distinguiendo las relaciones entre procesos padres e hijos.
  Podremos:
  - Notar si el malware dispara procesos nuevos.
  - Verificar archivos de Windows firmados digitalmente, para chequear si el malware ha reemplazado algún archivo con contenido malicioso.
  - Comparar strings entre el proceso en ejecución y el archivo en disco.
  - etc.

# Análisis dinámico básico - Herramientas online

## Detección rápida con servicios online.

Utilizar servicios como:

- https://hybrid-analysis.com
- https://any.run

Donde podemos enviar nuestra muestra de malware para que la ejecuten en una VM y nos generen un reporte rápido del comportamiento del malware.

# Análisis dinámico básico

## Simular conexión a internet con Fakenet

Frecuentemente el malware intenta conectarse a internet. Con la herramienta Fakenet, podemos simular una conexión falsa y obtener indicadores de actividad de red sin estar necesariamente conectados a Internet. Estos indicadores pueden incluir nombres de dominio, direcciones ip, etc.
En caso de necesitar dar Internet al malware debemos estar muy seguros que el mismo no pasa por nuestra red.